

OWASP

Nice try diddy part2

1. Időtartam és csomagszám (5 pont)

A capture kb. 62,6 másodpercet fed le, és 2819 csomagot tartalmaz.

2. Szerverek és szolgáltatások port alapján (8 pont)

- 172.16.10.11 – a fő szerver: SYN-ek a 80/TCP (HTTP, 44x) és 443/TCP (HTTPS/TLS, 7x) portokra -> webszerver.
- Külső célok: 9.9.9.9 / 208.67.222.222 / 8.8.8.8 (normál esetben DNS-resolverek, itt HTTP/SMTTP kérést kaptak), 192.168.1.1 átjáró (21/TCP FTP-kísérlet, #440).
- Infrastruktúra: DNS 53/UDP és NTP 123/UDP szerverforgalom is jelen van.

3. Protokollok példacsomagokkal (10 pont)

Nyolc protokoll azonosítható (hol a faszomban van 10?):

- ARP – #10
- ICMP – #11
- DNS (53/UDP) – #1
- NTP (123/UDP) – #31
- DHCP (67–68/UDP) – #298
- HTTP (80/TCP) – #9 (kérés: #105)
- TLS/HTTPS (443/TCP) – #19
- FTP (21/TCP) – #440

4. Fő webes célpont (7 pont)

IP: 172.16.10.11, hostname: status.novacore.hu, port: 80/HTTP (a 47 HTTP-kérésből 44 ide és erre a hostra megy).

5. Normál böngészési forgalom (10 pont)

- #171 GET /home
- #482 GET /index.html
- #304 GET /sitemap.xml
- #506 GET /robots.txt
- #1292 GET /static/style.css
- #176 GET /images/header.jpg

A fenti kérések egyszerű statikus/navigációs útvonalak, paraméter nélkül vagy statikus erőforrásra, nincs bennük ../, idézőjel, SQL-kulcsszó vagy egyéb injektálási minta

6. Path traversal / LFI (12 pont)

Mind 172.16.10.11 (status.novacore.hu) felé:

- #114 path=../../../../etc/shadow → param path, célfájl /etc/shadow

- #296 cat=../../../../etc/passwd → param cat, /etc/passwd
- #1816 name=..%5C..%5C..%5Cwindows%5C...%5Chosts → param name, URL-kódolt backslash (%5C), Windows hosts
- #2432 search=../../../../windows/system32/.../hosts → param search, Windows hosts
- #2604 item=.....//.....//etc/passwd → param item,// szűrő-bypass, /etc/passwd
- #2677 q=/proc/self/enviro → param q, /proc/self/enviro

7. SQL injection (10 pont)

Forrás: 192.168.9.67 → 172.16.10.11:

- #2079 /index.php?page=' OR 1=1 LIMIT 1-- ## OR 1=1 *ÉS* komment --
- #2135 /index.php?file=' OR '1'='1'-- ###URL-kódolt idézőjel (%27) *ÉS* OR '1'='1'
- #2211 /index.php?id=1 OR 1=1 – ###OR 1=1 feltétel

Árulkodó: URL-kódolt idézőjelek, OR 1=1 tautológia, -- komment.

8. POST /login (10 pont)

Mind 192.168.6.180 → 172.16.10.11:

- #193 admin / wrong_pass1
- #772 admin / password123
- #1098 root / root
- #1858 administrator / password123

Egyetlen forrásból több user/jelszó páros, tehát brute-force / credential stuffing támadás.

9. ARP-forgalom (8 pont)

A 192.168.1.1 **8 különböző MAC-címmel szerepel**. Egy IP-hez nem tartozhat több MAC, egy ez ARP spoofing / ARP cache poisoning, ami Man-in-the-Middle (MITM) támadásra utal!

10. Incidens-összefoglaló (15 pont)

- Fő célpont: 172.16.10.11 (status.novacore.hu), 80/HTTP. Másodlagosan az átjáró (192.168.1.1).
- Webes réteg jelei: Path traversal/LFI (#114, #296, #1816, #2432, #2604, #2677), SQL injection 192.168.9.67-ről (#2079, #2135, #2211), login brute-force 192.168.6.180-ról (#193, #772, #1098, #1858).
- Hálózati réteg jelei: ARP spoofing a 192.168.1.1 ellen (8 MAC, MITM); gyanús DNS-lekérdezés #1 (...tunnel.wikipedia.com) – DNS-tunneling jellegű exfiltráció.
- Legsúlyosabb jelek: /etc/shadow és /proc/self/enviro elérési kísérlet (jelszóhash / RCE potenciál), ARP poisoning (forgalom lehallgatható), root/administrator jelszótörés.
- Javasolt további vizsgálat: szerver válaszkódjainak ellenőrzése (200 vs 403/404) a sikeres LFI/SQLi azonosítására; a 192.168.9.67, 192.168.6.180 és a traversal-források gépeinek vizsgálata; statikus ARP / Dynamic ARP Inspection bevezetése

és a hamis MAC switch-portjának beazonosítása; a DNS-tunneling endpoint forgalmának külön elemzése.